IAM Security Lab
Security Audit Report

Active Directory • Microsoft Entra ID • Auth0

Self-directed portfolio project | October 2026

This report covers the security review part of my lab. It is based on a test environment, not a production audit.

1. Overview

This IAM lab was developed to gain practical experience with identity and access management. Following the configuration of users, groups, application access and authentication controls, a security review was carried out to identify opportunities for improvement.

The review identified a weak domain password policy, unnecessary group memberships and an application registration without an assigned owner. Other areas, including privileged access and service account ownership, were flagged for further investigation.

2. What I reviewed

- Active Directory users, groups and the default domain password policy.
- Microsoft Entra ID Conditional Access policies and an application registration.
- Access review results and group membership changes.
- Two service accounts in Active Directory.
- Federated sign-in between Entra ID and Auth0.
- Microsoft Entra ID user inventory containing 12 lab accounts.

PowerShell and the relevant administration portals were used to review configurations and apply changes. Confirmed results are distinguished from areas requiring further testing.

The Entra ID environment contained 12 user accounts used for identity administration, group assignments and authentication testing. Selected accounts were used to test federated authentication and MFA registration; a complete user-by-user security assessment was not performed.

3. Active Directory password policy

One of the clearest issues was the default domain password policy. The minimum password length was only seven characters, and the account lockout threshold was set to zero, meaning lockout was disabled.

Setting	Before	After
Minimum length	7	14
Complexity	Enabled	Enabled
Password history	24	24
Maximum password age	42 days	No routine expiry
Lockout threshold	Disabled	10 failed attempts
Lockout duration	30 minutes	30 minutes

The policy was updated using PowerShell and the revised settings were verified. Changes included a longer minimum password length, an account lockout threshold and removal of routine password expiry. In a production environment, the latter would need to be supported by MFA, compromised-password detection and a clear password reset process.

Outcome: Configuration updated and verified. Existing user passwords were not individually reset or assessed.

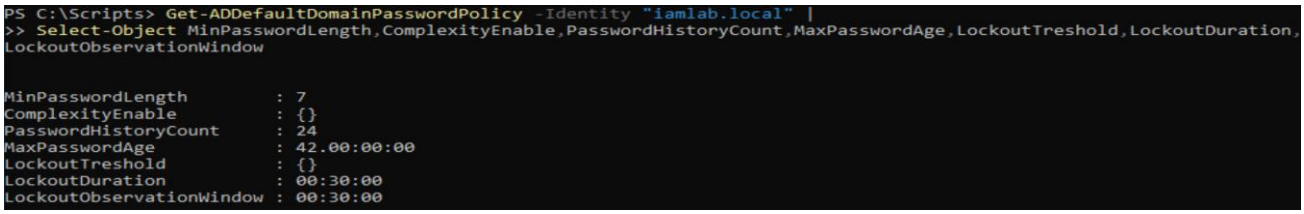


Figure 1: Password policy before remediation



Figure 2: Password policy after remediation

4. MFA and Conditional Access

Four Conditional Access policies were configured in Entra ID to support MFA, administrative access restrictions, risky sign-in protection and device compliance requirements.

Policy	Status shown
CA001 - Block Non-Compliant Devices	On
CA002 - Require MFA - All Users	On
CA003 - Restrict Admin Portal - Locations	On
CA004 - Require MFA - Risky Sign-ins	On

Four Microsoft-managed policies were also shown as On, including controls for legacy authentication and MFA. The policy list was captured as evidence.

The available evidence confirms that the policies were enabled. Policy conditions, exclusions and sign-in scenarios were not tested comprehensively, so full enforcement across the environment cannot be confirmed.

MFA coverage assessment

Although MFA-related Conditional Access policies were enabled, a complete user-by-user MFA registration assessment was not carried out. MFA coverage across all 12 Entra ID accounts could therefore not be confirmed. Reviewing authentication method registration and sign-in records would be a useful follow-up.

MFA authentication testing

During the Auth0 federation stage, a Microsoft Entra ID test account was used to validate the authentication process. On initial sign-in, the account was prompted to register multifactor authentication (MFA).

MFA registration was successfully completed, followed by a successful sign-in through the federated authentication flow. This demonstrated successful MFA registration and federated authentication for the tested account, but did not establish MFA enforcement or coverage across every account.

Policy name	Created by	State	Alert
Block legacy authentication	MICROSOFT	On	
Multifactor authentication for Azure Management	MICROSOFT	On	
Multifactor authentication for admins	MICROSOFT	On	
Multifactor authentication for all users	MICROSOFT	On	
CA001 - Block Non-Compliant Devices	USER	On	
CA002 - Require MFA - All Users	USER	On	
CA003 - Restrict Admin Portal - Locations	USER	On	
CA004 - Require MFA - Risky Sign-ins	USER	On	

Figure 3: Conditional Access Policies

5. Privileged access

The access review flagged test account jboom as a member of the Admin-Access group. Administrative access should be supported by a clear justification.

The permissions granted by Admin-Access were not verified, and a full Domain Admins review was not completed. This was therefore recorded as a finding requiring investigation, rather than confirmed inappropriate access.

A complete inventory of administrative accounts and privileged role assignments was not produced. A follow-up review should document privileged identities, their assigned permissions and the justification for retaining access.

Next step in a real environment: check the group's permissions, confirm the user's role and remove access only if it is no longer required.

6. Access review and least privilege

The access review identified test account sdunce (Sarah Dunce) as a member of IT-Staff, HR-Staff, Sales-Staff and Domain Users. For the lab exercise, the IT and HR memberships were considered unnecessary.

The IT-Staff and HR-Staff memberships were removed. A follow-up check confirmed that the account retained Domain Users and Sales-Staff memberships, as intended.

This demonstrates how access reviews can identify departmental permissions that are no longer needed, particularly following changes in responsibilities.

Outcome: Unnecessary lab group memberships removed and verified

Stale account assessment (90+ days)

A complete review of accounts with no sign-in activity for 90 days or more was not carried out. Future checks should review Active Directory logon data and Entra ID sign-in records, then confirm whether any potentially inactive accounts are still required before changing their access.

```
PS C:\Scripts> Get-ADPrincipalGroupMembership -Identity sdunce | Select-Object Name

Name
----
Domain Users
IT-Staff
HR-Staff
Sales-Staff
```

Figure 4: Before remediation of group memberships

```
PS C:\Scripts> Get-ADPrincipalGroupMembership -Identity "sdunce" | Select-Object Name

Name
----
Domain Users
Sales-Staff
```

Figure 5: After remediation of group memberships

7. Service accounts and application identity

Service accounts

Two Active Directory service accounts were reviewed: svc_backup and svc_monitoring. Both were disabled, neither had an owner recorded in the ManagedBy field, and neither showed a PasswordLastSet value in the collected results.

```
PS C:\Scripts> Get-ADUser -Filter 'SamAccountName -like "svc_*"' -Properties Enabled,Description,LastLogonDate | Select-
Object Name,SamAccountName,Enabled,Description,LastLogonDate,DistinguishedName | Format-List


Name              : svc_backup
SamAccountName    : svc_backup
Enabled           : False
Description       : Lab backup service account
LastLogonDate     :
DistinguishedName : CN=svc_backup,OU=Services Accounts,DC=iamlab,DC=local

Name              : svc_monitoring
SamAccountName    : svc_monitoring
Enabled           : False
Description       : Lab monitoring service account
LastLogonDate     :
DistinguishedName : CN=svc_monitoring,OU=Services Accounts,DC=iamlab,DC=local
```

Figure 6: Service Accounts

The accounts were not deleted because their dependencies had not been checked. Recommended next steps are to document each account's owner and purpose, verify dependencies and then assess whether it should be retained or decommissioned.

Entra application registration

The Auth0 IAM Federation app registration was also reviewed. It had the delegated Microsoft Graph User.Read permission and one client secret named Auth0-Federation-Lab, expiring on 4 September 2027. No owner was initially assigned.

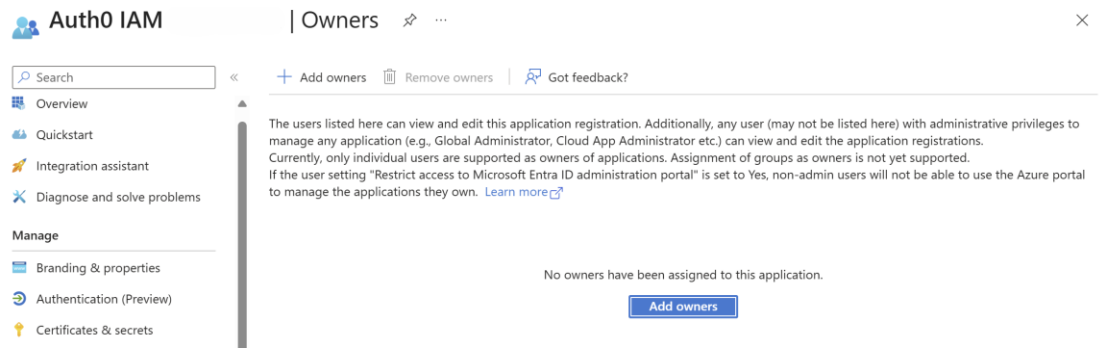


Figure 7: Application registration before owner assignment

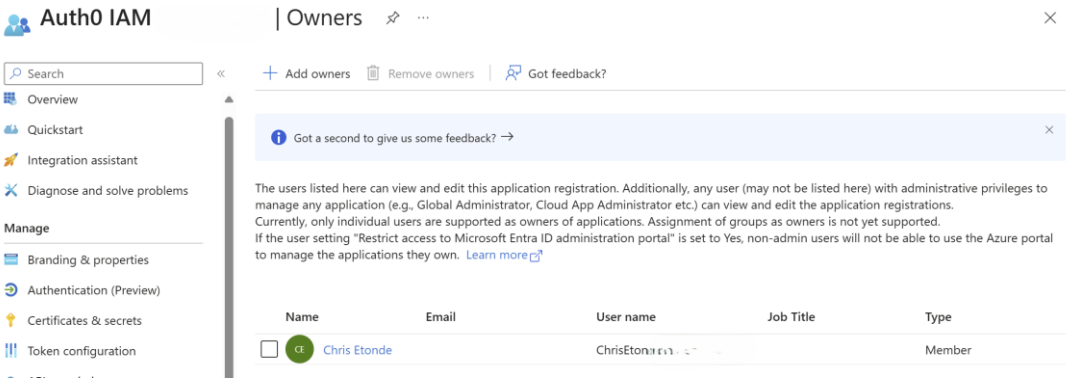


Figure 8: Application registration after owner assignment

Further recommendations include monitoring secret expiry and reviewing the application's permissions periodically.

8. Federation and application access

Microsoft Entra ID was connected with Auth0 using OpenID Connect. Selected sign-in and application access tests were carried out, alongside group-based application assignments.

This demonstrated how an identity provider supports application authentication and how group membership influences access. The planned Okta integration was not completed because of account registration requirements.

Federation testing included a successful sign-in using a Microsoft Entra ID test account following MFA registration. This provided evidence that the federated authentication flow worked for the tested account.

Further testing would be needed before considering the federation setup production-ready, particularly for failed sign-ins, access removal and authentication changes.

9. Summary of findings

Finding	Assessment	Outcome
Weak password and lockout settings	High priority	Fixed
Unnecessary departmental access	Medium priority	Fixed
Application registration missing owner	Medium priority	Fixed
Service accounts missing owners	Medium priority	To review
Admin-Access membership	Needs validation	To review
Conditional Access coverage	Needs validation	Further testing
MFA coverage across all users	Needs validation	Further assessment
Complete privileged account inventory	Needs validation	Further assessment
90-day stale account review	Not assessed	Review outstanding

These are qualitative priorities for the lab, not formal production risk scores. Recommended next steps include verifying privileged access, documenting service account ownership and testing Conditional Access policies against specific sign-in scenarios.

Prioritised recommendations

High priority — Privileged access: Complete an inventory of administrative accounts and verify the justification for assigned privileges.

High priority — MFA coverage: Review authentication method registration and sign-in records across the Entra ID user accounts.

Medium priority — Stale accounts: Review accounts with no sign-in activity for 90 days or more and determine whether access is still required.

Medium priority — Service accounts: Document account ownership, purpose and dependencies.

Medium priority — Conditional Access: Validate policy assignments, exclusions and enforcement through additional sign-in testing.

These recommendations are outstanding assessment activities rather than completed remediation.

10. What I learned

A key takeaway from the project is that IAM goes beyond user and group creation. Effective identity governance also requires regular access reviews, clear ownership of accounts and applications, and validation that security policies operate as intended.

Three issues were identified and remediated during the lab. Areas where the evidence was insufficient to reach a firm conclusion were documented separately, reflecting the importance of accurate reporting in IAM work.

Overall, the project provided practical experience with Active Directory, Entra ID, Auth0, PowerShell, access reviews and identity security controls.